Bezpieczne oprogramowanie i komponenty zewnętrzne

Materiał edukacyjny do demonstracji. Ogólne zagadnienia bezpieczeństwa informacji.

Zakres materiału

Uogólnione opracowanie edukacyjne zagadnień bezpieczeństwa rozwoju oprogramowania. Nie jest tekstem normy ISO/IEC 27001 ani opisem konkretnego procesu wytwórczego.

Wymagania bezpieczeństwa

Bezpieczeństwo należy uwzględniać przy definiowaniu wymagań, projektowaniu, implementacji, testowaniu i wdrożeniu. Zakres zabezpieczeń powinien odpowiadać zagrożeniom i znaczeniu systemu.

Kod i środowiska

Kod źródłowy powinien być chroniony przed nieuprawnionym odczytem i zmianą. Kontrola wersji, przegląd zmian i odpowiednie oddzielenie środowisk wspierają tę ochronę. Nie należy umieszczać haseł ani innych sekretów bezpośrednio w kodzie.

Komponenty zewnętrzne

Należy znać pochodzenie, wersje, warunki licencji i stan bezpieczeństwa wykorzystywanych bibliotek oraz narzędzi. Wybór i ponowne wykorzystanie komponentów powinny podlegać ocenie.

Licencje i prawa do rezultatów

Ocena komponentu powinna obejmować prawa do używania, modyfikowania i rozpowszechniania oraz obowiązki nakładane przez licencję. Warunki należy porównać ze zobowiązaniami umownymi dotyczącymi kodu i rezultatów prac.

Dane testowe

Dane do testów należy dobierać tak, aby chronić informacje poufne i dane osób. W publicznym środowisku demonstracyjnym należy używać danych przygotowanych do tego celu.

Testy i podatności

Zmiany wymagają sprawdzenia pod kątem błędów, podatności i spełnienia wymagań. Wykryte problemy powinny być rejestrowane, oceniane i usuwane. Wdrożenie powinno uwzględniać możliwość kontrolowanego wycofania zmian.